



Relatório da Análise de Segurança da aplicação Fuse

Código:	-
Versão:	1.0
Data da versão:	17/06/2026
Criado por:	Rafael Ferreira
Aprovado por:	-
Nível de confidencialidade:	 CONFIDENCIAL

Histórico de alterações

Data	Versão	Criado por	Descrição da alteração
16/06/2026	0.9	Rafael Ferreira	Versão Inicial
17/06/2026	1.0	Rafael Ferreira	Pequenas correções

Sumário

1. OBJETIVO, ÂMBITO E UTILIZADORES.....	3
2. INTRODUÇÃO.....	3
3. COMUNICAÇÃO SEGURA ENTRE SERVIDOR E CAMERA	4
3.1. UTILIZAÇÃO DE HTTP.....	4
3.2. DETECÇÃO DE PORTAS ONVIF VIA COMUNICAÇÃO NÃO ENCRYPTADA.....	4
4. AUDITORIA E RASTREABILIDADE	5
4.1. INEXISTENCIA DE PERFIL DE AUDITOR EXTERNO.....	5
4.2. INCLUSÃO DE DADOS SENSÍVEIS EM LOGS	5
5. ACESSO E PERMISSÕES	5
5.1. AUSÊNCIA DE VERIFICAÇÃO DE AUTORIZAÇÃO NA REPRODUÇÃO DE GRAVAÇÕES	5
5.2. VALIDAÇÃO DE IDENTIFICADORES POR <i>BLACKLIST</i> AO INVÉS DE <i>WHITELIST</i>	6
6. CONCLUSÃO.....	6

1. Objetivo, âmbito e utilizadores

A objetivo desta análise de segurança é avaliar a segurança e robustez da aplicação Fuse, bem como a sua prontidão para um *deployment* para produção. Neste documento será apresentado o resultado do da análise efetuada, incluindo uma explicação e verificação da arquitetura, todas as vulnerabilidades ou falhas detetadas e algumas recomendações para a sua mitigação.

No âmbito do teste está incluído apenas o ambiente de produção, mais especificamente as funcionalidades relacionadas com os seguintes temas: comunicação segura entre servidor e camera, auditoria e rastreabilidade, acessos e permissões. Qualquer aplicação, *framework* ou biblioteca externa encontra-se fora do âmbito desta análise.

Os destinatários deste documento são as partes interessadas, onde se incluem a equipa de desenvolvimento e coordenação da aplicação Fuse.

2. Introdução

A instalação foi realizada através dos comandos disponibilizados no ficheiro README.md do projeto e decorreu sem incidentes. Em poucos minutos a aplicação encontrava-se operacional e acessível via browser. Foi utilizado um ambiente baseado em Debian.

A aplicação Fuse assenta numa arquitetura relativamente simples, composta por dois conjuntos de dispositivos: um "pacote" de campo, que inclui um router 4G, uma câmara e um SBC (*Single Board Computer*); e um "pacote" de servidor, que aloja a aplicação propriamente dita. Nenhum destes dispositivos está exposto diretamente à internet. O único ponto de acesso externo é a *interface web*. A comunicação entre a câmara e o servidor é estabelecida através de um túnel privado, com recurso à ferramenta *Tailscale* (elaborado em maior detalhe na secção seguinte).

Esta decisão de arquitetura reduz substancialmente a superfície de ataque, uma vez que apenas os nós finais — câmara e servidor — estão potencialmente sujeitos a modificação ou comprometimento, e não a rede de transporte entre eles. Ainda assim, esta abordagem não elimina todos os riscos: a segurança da solução depende também da correta configuração do *Tailscale* (nomeadamente das ACLs e da gestão de chaves de autenticação dos nós) e do facto de que dispositivos dentro da mesma rede privada continuam a comunicar entre si sem inspeção adicional, pelo que um eventual comprometimento de um nó poderia, em teoria, ser usado para explorar outros serviços acessíveis dentro da mesma rede *Tailscale*.

Para a *interface web* foi utilizada a *framework Laravel*, amplamente adotada na indústria e sujeita a auditorias de segurança contínuas por parte da comunidade *open-source*. A utilização de uma *framework* madura mitiga uma classe significativa de vulnerabilidades comuns (como *SQL Injection*, através do *Eloquent ORM* e, por exemplo, *CSRF* através de *tokens* automáticos), reduzindo a probabilidade de falhas decorrentes de erros de implementação ou configuração incorreta. Ainda assim, a robustez da *framework* não elimina a necessidade de boas práticas no código aplicacional, nomeadamente validação de entradas, controlo de acesso e gestão segura de segredos, que permanecem da responsabilidade da equipa de desenvolvimento.

3. Comunicação Segura entre Servidor e Camera

Estes dois módulos do sistema utilizam a ferramenta *Tailscale* para poderem comunicar de forma segura, mesmo através de um sistema de rede 4G. O *Tailscale* usa, como base criptográfica e protocolo de transporte o *WireGuard*. Este protocolo foi formalmente verificado e utiliza algoritmos modernos e seguros como *ChaCha20* para encriptação simétrica, *Poly1305* para autenticação, *Curve25519* para troca de chaves e *BLAKE2* para hashing. Nenhum dos dispositivos consegue comunicar com outro sem que se autenticuem mutuamente. Só depois deste passo é que os nós são registados no servidor de coordenação e, consequentemente, descobríveis. Pelo que não é possível que um dispositivo desconhecido entre na rede privada.

Como o sistema usa rede 4G com NAT, o *Tailscale* utiliza o “*Hole Punching*” (via STUN/DERP) para estabelecer uma ligação *peer-to-peer* (P2P), sem que seja necessário abrir nenhuma porta no router. Se este mecanismo falhar, o tráfego irá passar pelos servidores DERP da *Tailscale*, porém esta comunicação está encriptada ponto-a-ponto.

Apesar da ferramenta *Tailscale* ser considerada segura, há alguns aspetos a ter em conta, nomeadamente:

- O acesso físico aos dispositivos. Na eventualidade de um ator malicioso ter acesso físico a um dos dispositivos poderá extrair as chaves *Tailscale* aí armazenadas.
- Dependência do servidor de coordenação *Tailscale*. A troca de chaves depende da infraestrutura da *Tailscale* para ser bem-sucedida. Uma alternativa *open-source* e *self-hosted* é o *HeadScale*.
- O *WireGuard* não implementa *perfect forward secrecy*, e, portanto, esta funcionalidade está dependente da camada de sessão *Tailscale*, onde é efetuada a rotação de chaves.

3.1. Utilização de HTTP

Verificou-se que diversos serviços internos da aplicação, assumem por defeito comunicação através do protocolo HTTP, conforme definido num dos ficheiros de configuração. Esta comunicação ocorre entre o servidor e serviços internos responsáveis pela gestão de *stream* de vídeo, controlo de câmaras e análise de eventos. Embora estas comunicações decorram, na arquitetura atual, dentro de uma rede privada e isolada, a ausência de encriptação no transporte significa que, num cenário em que a rede subjacente não fosse de confiança, ou no caso de um nó da rede ser comprometido, o tráfego entre estes serviços estaria exposto a interceção ou manipulação, incluindo eventuais segredos ou credenciais transmitidos no corpo dos pedidos.

3.2. Detecção de portas ONVIF via comunicação não encriptada

No processo de descoberta automática de portas e protocolos ONVIF, a aplicação efetua pedidos HTTP e HTTPS sucessivos às câmaras de forma a identificar o ponto de acesso correto ao serviço ONVIF. Foi verificado que, nas tentativas realizadas sobre HTTPS, a verificação do certificado TLS é explicitamente desativada, de forma a acomodar câmaras que utilizem certificados autoassinados, facto que é comum neste tipo de dispositivos. Esta configuração implica que a aplicação não verifique a autenticidade do dispositivo com o qual está a comunicar, pelo que, num cenário de rede

comprometida, seria possível a um atacante posicionar-se entre a aplicação e a câmara (ataque de *Machine-in-the-Middle*) sem que tal fosse detetado.

4. Auditoria e Rastreabilidade

4.1. Inexistencia de perfil de auditor externo

Evidenciou-se que o sistema possui um mecanismo de rastreabilidade aplicável a todos os utilizadores. Porém, foi identificada uma lacuna relevante no processo de criação de novos utilizadores. Constatou-se que um utilizador com perfil de super administrador tem acesso total ao sistema de forma automática, sem qualquer mecanismo de deliberação, aprovação ou registo de auditoria específico para essa atribuição de privilégios. Isto é, o utilizador que executa ações com privilégios elevados é o mesmo que realiza as ações de auditoria. Esta situação compromete o princípio de separação de funções (*segregation of duties*), na medida em que não existe um perfil independente, por exemplo, um auditor externo ou um segundo administrador, capaz de validar ou monitorizar a atribuição de privilégios elevados.

Recomenda-se a criação de um mecanismo de rastreabilidade segregado e específico para ações realizadas por utilizadores com poder administrativo, distinto do mecanismo de auditoria geral aplicado aos restantes utilizadores, de forma a garantir que qualquer atribuição ou alteração de privilégios administrativos é registada, visível e sujeita a um processo de revisão independente.

4.2. Inclusão de dados sensíveis em *logs*

Verificou-se que quando existe a geração de um *log*, decorrente de uma falha na movimentação da camera, está a ser incluindo o *body* do pedido HTTP. Esta facto poderá originar a escrita de credenciais de acesso ou segredos nos ficheiros de *log*.

Recomenda-se que apenas os dados estritamente necessários para a realização de uma auditoria ou rastreamento sejam incluídos nestes ficheiros.

5. Acesso e Permissões

5.1. Ausência de verificação de autorização na reprodução de gravações

Na análise a um dos controladores responsável pelas de gravações, não foi possível confirmar que aquando da reprodução de segmentos de vídeo já foi realizado o processo de autenticação e autorização do receptor dos dados.

Esta situação configura uma falha de configuração, uma vez que o controlo de acesso a conteúdo sensível (gravações de câmaras) não deve depender exclusivamente da dificuldade em adivinhar identificadores de câmara ou caminhos de ficheiro, mas sim de uma verificação explícita e obrigatória de que o utilizador autenticado possui permissão para aceder ao recurso solicitado.

5.2. Validação de identificadores por *blacklist* ao invés de *whitelist*

Observou-se que a validação dos identificadores de câmara fornecidos nos pedidos recorre a uma abordagem de lista negra (*blacklist*), rejeitando determinadas sequências de caracteres. Esta abordagem é suscetível a um *bypass* através de técnicas como *double encoding* ou da utilização de caracteres alternativos não previstos na lista de exclusão, permitindo, em determinados cenários, o acesso a ficheiros fora do diretório pretendido. Recomenda-se a adoção de uma abordagem de lista branca (*whitelist*), na qual apenas os caracteres explicitamente permitidos são aceites, reduzindo significativamente o risco de contorno do mecanismo de validação.

6. Conclusão

A análise efetuada à aplicação Fuse permite concluir que o sistema apresenta, de forma global, uma postura de segurança sólida, sustentada por escolhas de arquitetura bem fundamentadas. A utilização do *Tailscale*, para a comunicação entre câmaras e servidor garante autenticação mútua, encriptação ponto-a-ponto e uma superfície de ataque significativamente reduzida, ao limitar o acesso externo exclusivamente à interface *web*. Adicionalmente, a adoção de uma *framework* madura e amplamente testada na indústria, complementada por mecanismos como assinatura *HMAC*, comparação de *strings* em tempo constante e validação extensiva de *payloads*, demonstra uma preocupação consistente com boas práticas de desenvolvimento seguro.

Não obstante este balanço globalmente positivo, foram identificadas um conjunto de fragilidades que, embora não comprometam de forma imediata a integridade geral do sistema no contexto da arquitetura atual, devem ser endereçadas antes de uma utilização em ambiente de produção com dados sensíveis ou exposição a redes menos controladas. Destacam-se, em particular, a ausência de verificação explícita de autorização na reprodução de gravações de câmaras, e a inclusão pontual de dados potencialmente sensíveis em ficheiros de log. Foi também identificada a utilização de comunicação não encriptada e de verificação *TLS* relaxada entre alguns serviços internos, risco que se encontra atualmente mitigado pela natureza inerentemente isolada da rede, mas que deve ser tido em conta caso o modelo de implementação venha a ser alterado.

Face ao exposto, considera-se que a aplicação Fuse reúne, na sua generalidade, condições de segurança adequadas ao contexto e arquitetura para os quais foi concebida. A aplicação está próxima de atingir um grau de maturidade em linha com um *deploy* em produção. Recomenda-se, no entanto, que as vulnerabilidades identificadas sejam corrigidas antes de uma disponibilização em ambiente de produção ou perante um aumento da superfície de exposição do sistema. Quando as remediações e mitigações para as falhas e/ou erros encontrados forem executadas, a aplicação estará pronta para assegurar um nível de segurança consistente com as exigências de um sistema de videovigilância em ambiente realista.